Tata Kelola dan Manajemen Teknologi Informasi

Struktur, Komponen, Area Fokus dan Faktor Desain Tata Kelola dan Manajemen TI

Team Teaching ISM

S1 Sistem Informasi – Fakultas Rekayasa Industri

Outline

1. **Structure** of Governance and Management Objectives
2. **Components** of the Governance System
3. COBIT 2019 **Focus Areas**
4. COBIT 2019 **Design Factors**

1. Structure

1. Objectives

Figure 3.1—Display of Governance and Management Objectives	
Domain: <NAME> **Governance/Management Objective:** <NAME>	**Focus Area:** <NAME>
Description	
<TEXT>	
Purpose	
<TEXT>	

- Example : DSS02-Managed Service Requests and Incidents

Domain: Deliver, Service and Support **Management Objective: DSS02 - Managed Service Requests and Incidents**	**Focus Area: COBIT Core Model**
Description	
Provide timely and effective response to user requests and resolution of all types of incidents. Restore normal service; record and fulfil user requests; and record, investigate, diagnose, escalate and resolve incidents.	
Purpose	
Achieve increased productivity and minimize disruptions through quick resolution of user queries and incidents. Assess the impact of changes and deal with service incidents. Resolve user requests and restore service in response to incidents.	

2. Goals Cascade

Figure 3.2—Display of Applicable Enterprise and Alignment Goals		
The governance/management objective supports the achievement of a set of primary enterprise and alignment goals:		
Enterprise Goals	→	**Alignment Goals**
• <EG REF> <GOAL DESCRIPTION>		• <AG REF> <GOAL DESCRIPTION>

- Example : EDM04-Ensured Resource Optimization

The management objective supports the achievement of a set of primary enterprise and alignment goals:		
Enterprise Goals	→	**Alignment Goals**
• EG01 Portfolio of competitive products and services • EG08 Optimization of internal business process functionality		AG05 Delivery of I&T services in line with business requirements

3. Applicable Goals and Example Metrics

Figure 3.3—Display of Applicable Goals and Example Metrics

The governance/management objective supports the achievement of a set of primary enterprise and alignment goals:

Enterprise Goals		Alignment Goals
<EG REF> <GOAL DESCRIPTION>		<AG REF> <GOAL DESCRIPTION>
Example Metrics for Enterprise Goals		**Example Metrics for Alignment Goals**
<EG REF> • <METRIC>		<AG REF> • <METRIC>
<EG REF> • <METRIC>		<AG REF> • <METRIC>

- Example : EDM04-Ensured Resource Optimization

Example Metrics for Enterprise Goals		Example Metrics for Alignment Goals
EG01	a. Percent of products and services that meet or exceed targets in revenues and/or market share b. Percent of products and services that meet or exceed customer satisfaction targets c. Percent of products and services that provide competitive advantage d. Time to market for new products and services	AG05 a. Percent of business stakeholders satisfied that I&T service delivery meets agreed service levels b. Number of business disruptions due to I&T service incidents c. Percent of users satisfied with the quality of I&T service delivery
EG08	a. Satisfaction levels of board and executive management with business process capabilities b. Satisfaction levels of customers with service delivery capabilities c. Satisfaction levels of suppliers with supply chain capabilities	

2. Components

Components of the Governance System

- Previously known as COBIT enablers in COBIT 5
- Components contribute to enterprise's governance over IT
- Components interact with each other
- Components can be of different types :
  - processes. organizational structures; policies and procedures; information items;
  - culture and behavior; skills and competencies; and services, infrastructure and applications.

Components of the Governance System (2)

- Processes
  - Set of practices
  - Produces a set of outputs
  - Support IT related goals
- Organizational Structures
  - Decision making entities
- Principles, policies and Frameworks
  - Guidance for day to day management



Components of the Governance System (3)

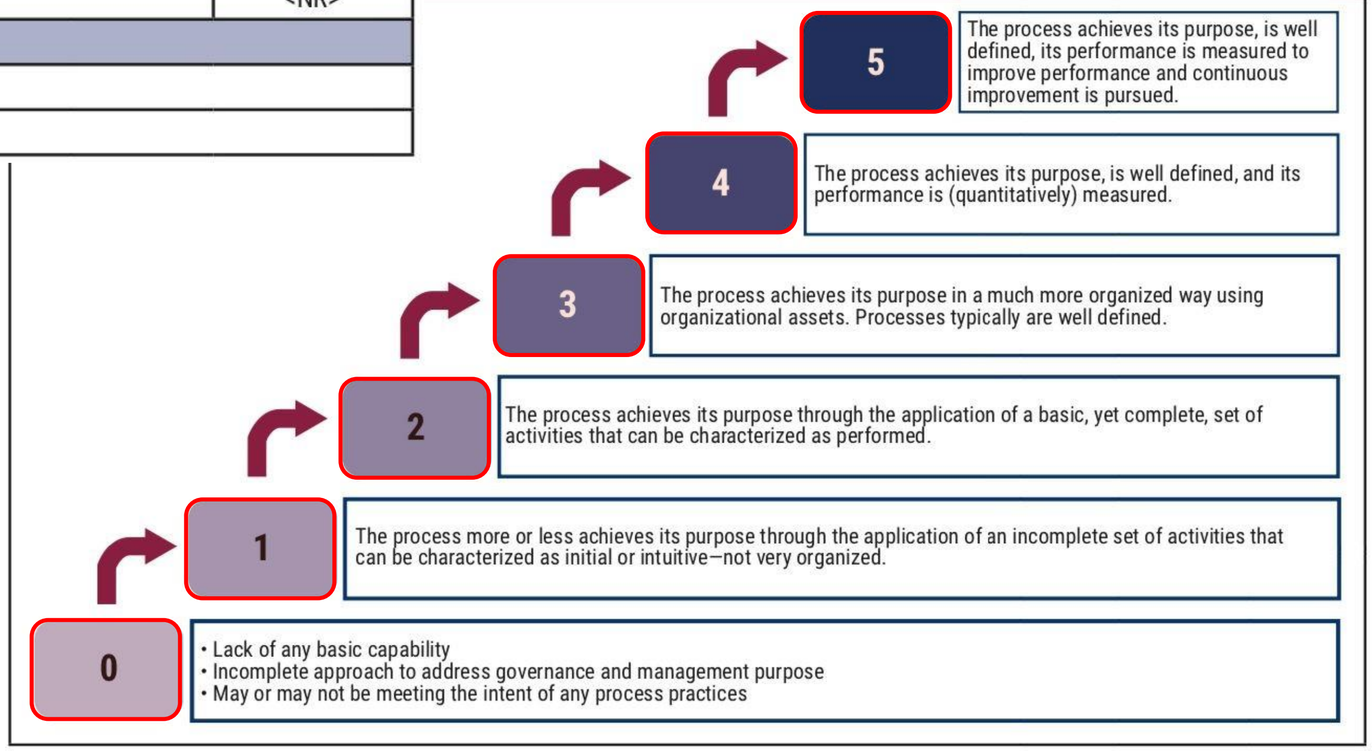
- Information
  - For effective functioning of governance system
- Cultures, Ethics and Behavior
  - Often underestimated
- People, Skills and Competencies
  - For good decisions
  - And execution of activities
- Services, Infrastructure and Applications
  - That provide the governance system for I&T



A. Process Component

Figure 3.4—Display of Process Component	
A. Component: Process	
Governance/Management Practice	**Example Metrics**
<REF> <NAME> <DESCRIPTION>	<METRIC>
Activities	**Capability Level**
1. <TEXT>	<NR>
2. <TEXT>	<NR>
n. <TEXT>	<NR>
Related Guidance (Standards, Frameworks, Compliance Requirements)	**Detailed Reference**
<STANDARD NAME>	<TEXT>
<STANDARD NAME>	<TEXT>

Figure 3.5—Capability Levels for Processes



Example: Process Component of DSS02

A. Component: Process	
Management Practice	**Example Metrics**
DSS02.01 Define classification schemes for incidents and service requests. Define classification schemes and models for incidents and service requests.	a. Total number of service requests and incidents per priority level b. Total number of incidents escalated
Activities	**Capability Level**
1. Define incident and service request classification and prioritization schemes, and criteria for problem registration. Use this information to ensure consistent approaches for handling and informing users about problems and conducting trend analysis.	3
2. Define incident models for known errors to enable efficient and effective resolution.	
3. Define service request models according to service request type to enable self-help and efficient service for standard requests.	
4. Define incident escalation rules and procedures, especially for major incidents and security incidents.	
5. Define knowledge sources on incidents and requests and describe how to use them.	
Related Guidance (Standards, Frameworks, Compliance Requirements)	**Detailed Reference**
CMMI Cybermaturity Platform, 2018	IA.IP Implement Incident Investigation Processes
HITRUST CSF version 9, September 2017	11.01 Reporting Information Security Incidents and Weaknesses
ISF, The Standard of Good Practice for Information Security 2016	TM2 Security Incident Management
ISO/IEC 20000-1:2011(E)	8.1 Incident and service request management
ISO/IEC 27002:2013/Cor.2:2015(E)	16. Information security incident management

B. Organizational Structures Component

Figure 3.6—Display of Organizational Structures Component								
B. Component: Organizational Structures								
Key Governance/Management Practice	**Organizational Structure 1**	**Organizational Structure 2**	**Organizational Structure 3**	**Organizational Structure 4**	**Organizational Structure 5**	**Organizational Structure 6**	**Organizational Structure 7**	**Organizational Structure 8, etc.**
<REF> <NAME>								

Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference
<STANDARD NAME>	<TEXT>
<STANDARD NAME>	<TEXT>

Organizational Structures and Roles

- Board
- Executive Committee
- CEO, CFO, CTO, COO, CRO, CIO, CDO
- I&T Governance board, Architecture board, Enterprise Risk committee
- Portfolio manager, program manager, project manager
- Roles
  - Responsible : operational responsibility
  - Accountable : overall accountability
  - Consulted : who is providing the input
  - Informed : who is receiving the information

Example: Organizational Structures of DSS02

B. Component: Organizational Structures							
Key Management Practice	**Chief Technology Officer**	**Business Process Owners**	**Head Development**	**Head IT Operations**	**Service Manager**	**Information Security Manager**
DSS02.01 Define classification schemes for incidents and service requests.	A		R	R	R	
DSS02.02 Record, classify and prioritize requests and incidents.	A			R	R	
DSS02.03 Verify, approve and fulfil service requests.	A	R	R	R	R	
DSS02.04 Investigate, diagnose and allocate incidents.	A	R		R	R	
DSS02.05 Resolve and recover from incidents.	A		R	R	R	R
DSS02.06 Close service requests and incidents.	A			R	R	R
DSS02.07 Track status and produce reports.	A			R	R	

Related Guidance (Standards, Frameworks, Compliance Requirements)	**Detailed Reference**
ISO/IEC 27002:2013/Cor.2:2015(E)	16.1.1 Responsibilities and procedures

C. Information Flows and Items Component

Figure 3.7—Display of Information Flows and Items Component				
C. Component: Information Flows and Items				
Governance/Management Practice	**Inputs**		**Outputs**	
<REF> <NAME>	**From**	**Description**	**Description**	**To**
	<REF>	<TEXT>	<TEXT>	<REF>

Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference
<STANDARD NAME>	<TEXT>
<STANDARD NAME>	<TEXT>

Example: Information Flows and Items of DSS02

C. Component: Information Flows and Items (see also Section 3.6)				
Management Practice	**Inputs**		**Outputs**	
	From	**Description**	**Description**	**To**
DSS02.01 Define classification schemes for incidents and service requests.	APO09.03	SLAs	Criteria for problem registration	DSS03.01
	BAI10.02	Configuration repository	Rules for incident escalation	Internal
	BAI10.03	Updated repository with configuration items	Incident and service request classification schemes and models	Internal
	BAI10.04	Configuration status reports		
	DSS01.03	Asset monitoring rules and event conditions		
	DSS03.01	Problem classification scheme		
	DSS04.03	Incident response actions and communications		
DSS02.02 Record, classify and prioritize requests and incidents.	APO09.03	SLAs	Classified and prioritized incidents and service requests	APO08.03; APO09.04; APO13.03; DSS03.05
	BAI04.05	Emergency escalation procedure	Incident and service request log	Internal; MEA04.07
	DSS01.03	• Asset monitoring rules and event conditions • Incident tickets		
	DSS05.07	Security-related incident tickets		

D. Skills and Competencies Component

Figure 3.9—Display of People, Skills and Competencies Component		
D. Component: People, Skills and Competencies		
Skill	**Related Guidance (Standards, Frameworks, Compliance Requirements)**	**Detailed Reference**
<NAME>	Skills Framework for the Information Age, V6 (SFIA 6), 2015	<SFIA CODE>
<NAME>	Skills Framework for the Information Age, V6 (SFIA 6), 2015	<SFIA CODE>

- Example : DSS02-Managed Service Requests and Incidents

D. Component: People, Skills and Competencies		
Skill	**Related Guidance (Standards, Frameworks, Compliance Requirements)**	**Detailed Reference**
Application support	Skills Framework for the Information Age V6, 2015	ASUP
Customer service support	Skills Framework for the Information Age V6, 2015	CSMG
Incident management	Skills Framework for the Information Age V6, 2015	USUP
Network support	Skills Framework for the Information Age V6, 2015	NTAS
User support	e-Competence Framework (e-CF)—A common European Framework for ICT Professionals in all industry sectors—Part 1: Framework, 2016	C. Run—C.1. User Support

E. Policies and Procedures Component

Figure 3.10—Display of Policies and Procedures Component			
E. Component: Policies and Procedures			
Relevant Policy	**Policy Description**	**Related Guidance**	**Detailed Reference**
<NAME>	<DESCRIPTION>	<STANDARD NAME>	<TEXT>

- Example : DSS02-Managed Service Requests and Incidents

E. Component: Policies and Procedures			
Relevant Policy	**Policy Description**	**Related Guidance**	**Detailed Reference**
Service request policy	States rationale and provides guidance for service and incident requests and their documentation.	ITIL V3, 2011	Service Operation, 3. Service operation principles

F. Culture, Ethics and Behavior Component

Figure 3.11—Display of Culture, Ethics and Behavior Component		
F. Component: Culture, Ethics and Behavior		
Key Culture Elements	**Related Guidance**	**Detailed Reference**
<NAME>	<STANDARD NAME>	<TEXT>

- Example : DSS02-Managed Service Requests and Incidents

F. Component: Culture, Ethics and Behavior		
Key Culture Elements	**Related Guidance**	**Detailed Reference**
Enable employees to identify incidents on a correct and timely basis and implement appropriate escalation paths. Encourage prevention. Respond to and resolve incidents immediately. Avoid a hero culture.		

G. Services, Infrastructure and Applications Component

Figure 3.12—Display of Services, Infrastructure and Applications Component
G. Component: Services, Infrastructure and Applications
<CATEGORY OF SERVICES, INFRASTRUCTURE OR APPLICATIONS>

- Example : DSS02-Managed Service Requests and Incidents

G. Component: Services, Infrastructure and Applications
Incident tracking tools and system

3. Focus Areas

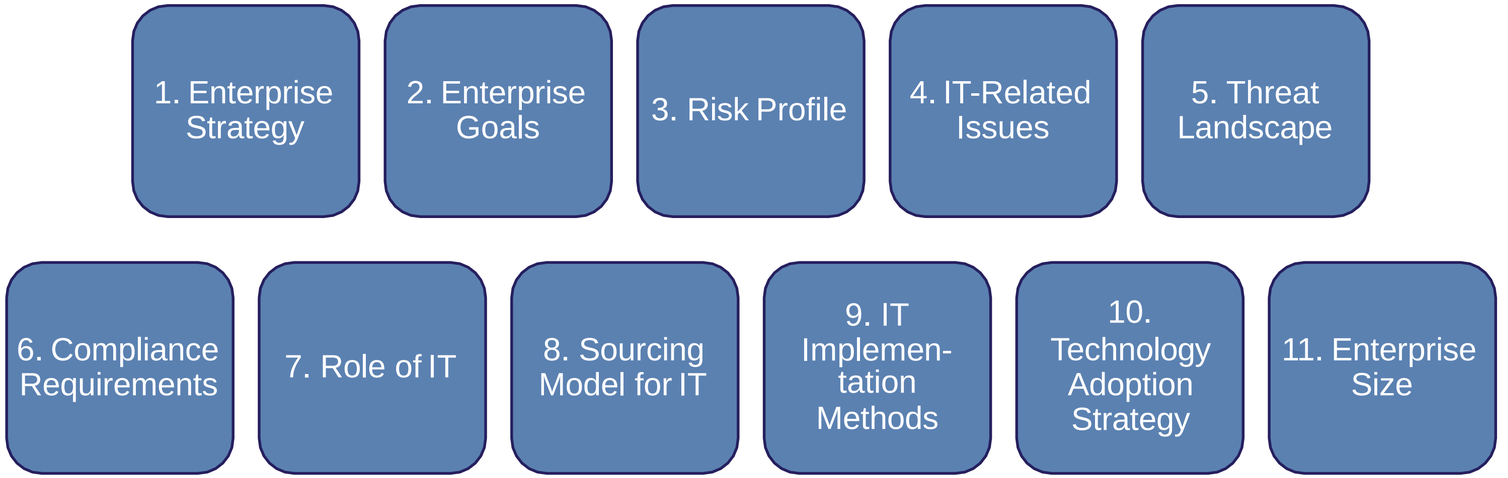
Generic/Variant Focus Area

- Generic components
  - Apply to any situation
  - Need customization
- Variant component
  - Based on generic components
  - Tailored for a specific area
  - Example of area : information security, DevOps, a regulation

4. Design Factors

COBIT 2019 Design Factors

Design factors are factors that can influence the design of an enterprise's governance system and position it for success in the use of IT. Design factors include any combination of the following:



1. Enterprise Strategy

Organizations typically have a primary strategy and, at most, one secondary strategy. Enterprises can have different strategies, which can be expressed as one or more of the following archetypes:

Strategy Archetype	Explanation
Growth/Acquisition	The enterprise has a focus on growing (revenues)
Innovation/Differentiation	The enterprise has a focus on offering different and/or innovative products and services to their clients
Cost leadership	The enterprise has a focus on short-term cost minimization
Client service/Stability	The enterprise has a focus on providing stable and client-oriented service

Example: Cost Leadership as a Focus Area

Mc-Donald's: Low cost position by

- Increasing productivity
- ➢ DSS01: **Managed Operations**
- Eliminating waste
- ➢ APO11: **Managed Quality**
- Controlling costs
- ➢ APO06: **Managed Budget and Cost**

2. Enterprise Goals

Supporting the enterprise strategy:

BSC dimension	Ref.	Enterprise goal
Financial	EG01	Portfolio of competitive products and services
	EG02	Managed business risk
	EG03	Compliance with external laws and regulations
	EG04	Quality of financial information
Customer	EG05	Customer-oriented service culture
	EG06	Business-service continuity and availability
	EG07	Quality of management information
Internal	EG08	Optimization of internal business process functionality
	EG09	Optimization of business process costs
	EG10	Staff skills, motivation and productivity
	EG11	Compliance with internal policies
Growth	EG12	Managed digital transformation programs
	EG13	Product and business innovation

Example: Focus on Competitive products and services

Enterprise Goal Selection → Prioritize Management Objectives

EG01 : Portfolio of competitive products and services

↓

APO05 : Managed Portfolio

3. Risk Profile

Risk profile of the enterprise:

1	IT investment decision making, portfolio definition & maintenance
2	Program & projects life cycle management
3	IT cost & oversight
4	IT expertise, skills & behavior
5	Enterprise/IT architecture
6	IT operational infrastructure incidents
7	Unauthorized actions
8	Software adoption/usage problems
9	Hardware incidents
10	Software failures
11	Logical attacks (hacking, malware, etc.)
12	Third-party/supplier incidents
13	Noncompliance
14	Geopolitical Issues
15	Industrial action
16	Acts of nature
17	Technology-based innovation
18	Environmental
19	Data & information management

4. IT-Related Issues

The most common issues include:

A	Frustration between different IT entities across the organization because of a perception of low contribution to business value
B	Frustration between business departments (i.e., the IT customer) and the IT department because of failed initiatives or a perception of low contribution to business value
C	Significant I&T-related incidents, such as data loss, security breaches, project failure and application errors, linked to IT
D	Service delivery problems by the IT outsourcer(s)
E	Failures to meet IT-related regulatory or contractual requirements
F	Regular audit findings or other assessment reports about poor IT performance or reported IT quality or service problems
G	Substantial hidden and rogue IT spending, that is, I&T spending by user departments outside the control of the normal I&T investment decision mechanisms and approved budgets
H	Duplications or overlaps between various initiatives, or other forms of wasted resources
I	Insufficient IT resources, staff with inadequate skills or staff burnout/dissatisfaction
J	IT-enabled changes or projects frequently failing to meet business needs and delivered late or over budget
K	Reluctance by board members, executives or senior management to engage with IT, or a lack of committed business sponsorship for IT
L	Complex IT operating model and/or unclear decision mechanisms for IT-related decisions
M	Excessively high cost of IT
N	Obstructed or failed implementation of new initiatives or innovations caused by the current IT architecture and systems
O	Gap between business and technical knowledge, which leads to business users and information and/or technology specialists speaking different languages
P	Regular issues with data quality and integration of data across various sources
Q	High level of end-user computing, creating (among other problems) a lack of oversight and quality control over the applications that are being developed and put in operation
R	Business departments implementing their own information solutions with little or no involvement of the enterprise IT department (related to end-user computing, which often stems from dissatisfaction with IT solutions and services)
S	Ignorance of and/or noncompliance with privacy regulations
T	Inability to exploit new technologies or innovate using I&T

Example: IT-Related Issues

Failures to meet IT-related regulatory or contractual requirements

- MEA-03: **Managed Compliance With External Requirements**
  - Monitor local and international laws
  - Review and adjust policies and procedures
  - Obtain and report assurance of compliance

5. Threat Landscape

Threat landscape under which the enterprise operates:

Threat Landscape	Explanation
Normal	The enterprise is operating under what are considered normal threat levels.
High	Due to its geopolitical situation, industry sector or particular profile, the enterprise is operating in a high-threat environment.

Example of High Threat Landscape

Geopolitical tensions, cyber attacks

Focus area: risk management, information security

- EDM03: **Ensure Risk Optimization**
- APO12: **Managed Risks**
- APO13: **Managed Security**
- DSS05: **Managed Security Services**

With higher target capability levels

6. Compliance requirements

Compliance requirements to which the enterprise is subject:

Regulatory Environment	Explanation
Low compliance requirements	The enterprise is subject to a minimal set of regular compliance requirements that are lower than average.
Normal compliance requirements	The enterprise is subject to a set of regular compliance requirements that are common across different industries.
High compliance requirements	The enterprise is subject to higher-than-average compliance requirements, most often related to industry sector or geopolitical conditions.

Example: Highly Regulated Environment

Highly regulated:

- Drug manufacturing, Nuclear, Government, Financial

High importance of:

- Documentation (information)
- Procedures and policies
- Some roles (organizational structures)

7. Role of IT

Role of IT for the enterprise:

Role of IT	Explanation
Support	IT is not crucial for the running and continuity of the business process and services, nor for their innovation.
Factory	When IT fails, there is an immediate impact on the running and continuity of the business processes and services. However, IT is not seen as a driver for innovating business processes and services.
Turnaround	IT is seen as a driver for innovating business processes and services. At this moment, however, there is not a critical dependency on IT for the current running and continuity of the business processes and services.
Strategic	IT is critical for both running and innovating the organization’s business processes and services.

Example: High Involvement of IT-Related Roles

- When IT is Strategic to the enterprise
- High involvement of IT roles (organizational structure)
- Understanding of business by IT

➢ APO02: **Managed Strategy**

➢ APO08: **Managed Relationships**

8. Sourcing Model for IT

Sourcing model for IT that the enterprise adopts:

Sourcing Model	Explanation
Outsourcing	The enterprise calls upon the services of a third party to provide IT services.
Cloud	The enterprise maximizes the use of the cloud for providing IT services to its users.
Insourced	The enterprise provides for its own IT staff and services.
Hybrid	A mixed model is applied, combining the other three models in varying degrees.

Example : Sourcing Model for IT

Insourced Model: in-house development and hosting

- APO03: **Managed Enterprise Architecture**
- APO11: **Managed Quality**
- BAI03: **Managed Solution Identification and Build**
- BAI07: **Managed Programs Requirements**
- BAI10: **Managed Configuration**

9. IT Implementation Methods

IT implementation methods that the enterprise adopts:

Sourcing Model	Explanation
Agile	The enterprise uses Agile development working methods for its software development.
DevOps	The enterprise uses DevOps working methods for software building, deployment and operations.
Traditional	The enterprise uses a more classic approach to software development (waterfall) and separates software development from operations.
Hybrid	The enterprise uses a mix of traditional and modern IT implementation, often referred to as “bimodal IT.”

Example: IT Implementation Methods

Enterprise Implements DevOps

- BAI03 Managed solutions identification and build
- BAI10 Managed configuration
- DSS01 Managed operation

10. Technology Adaption Strategy

Strategy:

Sourcing Model	Explanation
First mover	The enterprise generally adopts new technologies as early as possible and tries to gain first-mover advantage.
Follower	The enterprise typically waits for new technologies to become mainstream and proven before adopting them.
Slow adopter	The enterprise is very late with adoption of new technologies.

Example : Technology Adoption Strategy

Slow mover companies

- **Kodak**: missed opportunity in digital photography
- **Nokia**: developed phones for short term market demands

➢ APO04 : **Managed Innovation**

11. Enterprise size

Enterprise size:

Sourcing Model	Explanation
Large enterprise (Default)	Enterprise with more than 250 full-time employees (FTEs)
Small and medium enterprise	Enterprise with 50 to 250 FTEs

Thank You

That’s all